

Remediation su Metasploitable 2

Secondo report interventi su quattro criticità critiche

Studentessa	Corso	Target	Data della relazione
Martina Foresta	CyberSecurity	Metasploitable 2 - 192.168.50.101	4 ottobre 2026

Ho svolto gli interventi dalla macchina Kali verso Metasploitable 2. Ho scelto quattro finding Critical della scansione Nessus iniziale. Per ognuno riporto il problema osservato, la modifica che ho fatto e la verifica che ho potuto eseguire subito dopo.

Criticità selezionata	Azione finale	Evidenza immediata
VNC - password predefinita (5900)	Password cambiata con vncpasswd	Vecchia password respinta; nuova accettata
Tomcat AJP / Ghostcat (8009)	Connettore AJP rimosso dalla configurazione	Nessun listener; Nmap: closed
SSLv2/SSLv3 (25 e 5432)	Due regole firewall per un solo finding	Nmap: filtered su entrambe le porte
Bind shell senza autenticazione (1524)	Voce ingreslock commentata e xinetd riavviato	Nmap: closed

Punto di partenza

Prima delle modifiche ho controllato da Kali le porte dei servizi selezionati. Erano tutte aperte: questo è il riferimento che uso per leggere i controlli successivi.

```
(kali㉿kali)-[~]
$ nmap -sV -p 1524,5900,8009,25,5432 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 13:26 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0043s latency).

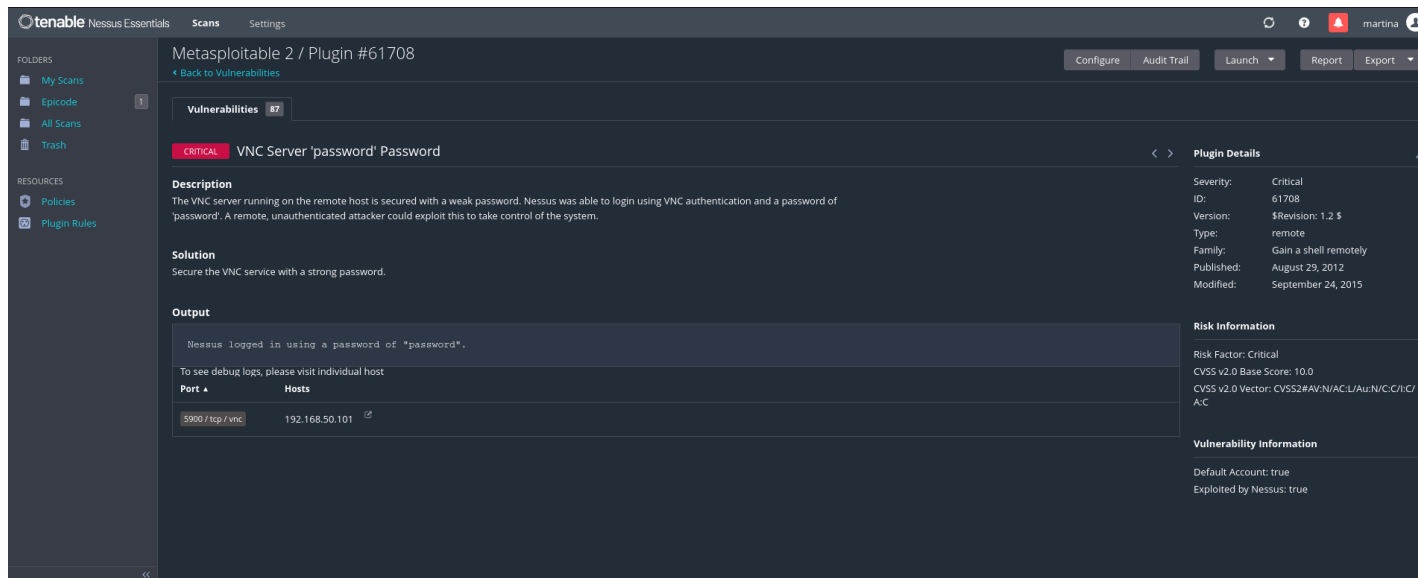
PORT      STATE SERVICE      VERSION
25/tcp    open  smtp         Postfix smtpd
1524/tcp  open  bindshell    Metasploitable root shell
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.14 seconds
```

1 Password VNC porta 5900

Finding Nessus	Porta/e	Intervento eseguito	Verifica disponibile
Plugin 61708 - VNC Server 'password' Password	5900/tcp	Sostituzione della password predefinita	Accesso vecchio negato, nuovo riuscito

Nessus era riuscito ad autenticarsi al server VNC usando la password predefinita 'password'. Ho verificato che la sessione grafica era raggiungibile da Kali: non si trattava soltanto di una porta aperta, ma di un accesso effettivo.



Modifica della credenziale

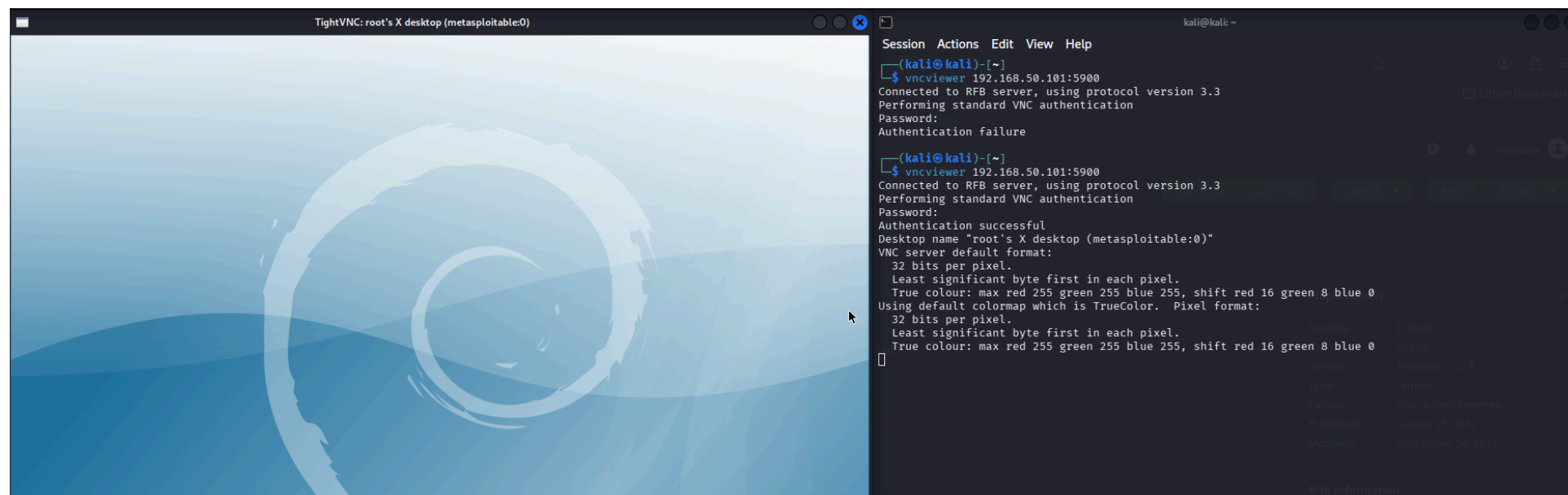
Nel terminale di Metasploitable ho usato vncpasswd. Il comando aggiorna il file della password VNC in /root/.vnc/passwd.

```
root@metasploitable: /
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:~#
```

Controllo da Kali

Ho ripetuto la connessione con vncviewer. La vecchia password ha prodotto 'Authentication failure'; con quella nuova l'autenticazione è riuscita e si è aperto il desktop remoto. La porta VNC resta aperta, ma la credenziale predefinita non dà più accesso.

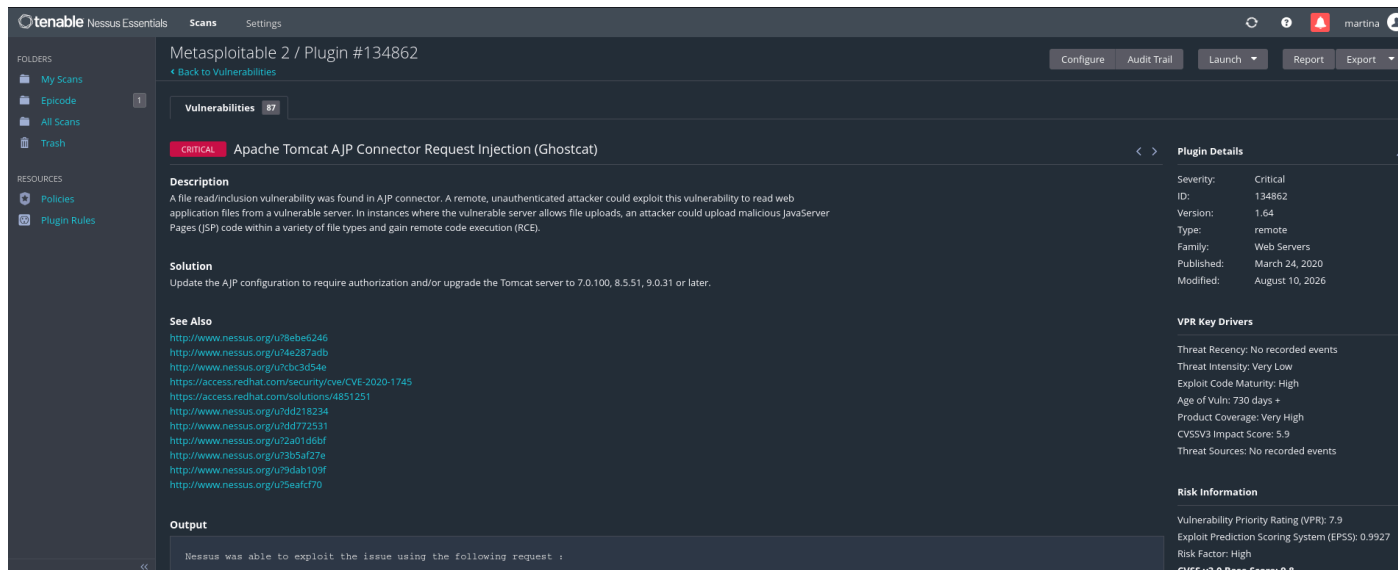
```
vncviewer 192.168.50.101:5900
```



2 Tomcat AJP Ghostcat porta 8009

Finding Nessus	Porta/e	Intervento eseguito	Verifica disponibile
Plugin 134862 - Apache Tomcat AJP Connector Request Injection	8009/tcp	Connettore AJP eliminato da server.xml	Tomcat attivo; 8009 senza listener e closed

Il finding Nessus riguardava il connettore AJP di Tomcat, esposto sulla porta 8009. In un primo momento avevo applicato un blocco firewall alla porta per verificarne l'effetto: Nmap la mostrava filtered. Ho poi scelto un intervento sul servizio, perché AJP non serviva in questa esercitazione. Ho rimosso il filtro temporaneo dopo la modifica, così la verifica finale non dipende da quella regola.



Individuazione del file e copia di sicurezza

Il percorso `/var/lib/tomcat5.5/conf/server.xml` era un collegamento a `/etc/tomcat5.5/server.xml`. Con `grep` ho trovato il connettore AJP attivo alle righe 105-106.

```
readlink -f /var/lib/tomcat5.5/conf/server.xml
```

```
grep -n -A 1 8009 /etc/tomcat5.5/server.xml
```

```
(kali㉿kali)-[~]
$ nc 192.168.50.101 1524
root@metasploitable:/# readlink -f /var/lib/tomcat5.5/conf/server.xml
/etc/tomcat5.5/server.xml
root@metasploitable:/# grep -n -A 1 8009 /etc/tomcat5.5/server.xml
104:  <!-- Define an AJP 1.3 Connector on port 8009 -->
105:  <Connector port="8009"
106-      enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
root@metasploitable:/#
```

Rimozione del connettore

Ho eliminato solo le due righe che definivano il connettore AJP. Il controllo successivo mostrava ancora il commento descrittivo, ma non più la voce <Connector port="8009">.

```
sed -i '105,106d' /etc/tomcat5.5/server.xml
```

```
grep -n -A 4 8009 /etc/tomcat5.5/server.xml
```

```
root@metasploitable:/# grep -n -A 1 8009 /etc/tomcat5.5/server.xml
104:  <!-- Define an AJP 1.3 Connector on port 8009 -->
105:  <Connector port="8009"
106-      enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
root@metasploitable:/# sed -i '105,106d' /etc/tomcat5.5/server.xml
root@metasploitable:/# grep -n -A 4 8009 /etc/tomcat5.5/server.xml
104:  <!-- Define an AJP 1.3 Connector on port 8009 -->
105-
106-  <!-- Define a Proxied HTTP/1.1 Connector on port 8082 -->
107-  <!-- See proxy documentation for more information about using this. -->
108-  <!--
root@metasploitable:/#
```

2 Tomcat AJP Ghostcat avvio e verifica

Il primo comando di restart ha arrestato Tomcat ma non lo ha riportato subito in esecuzione. Ho controllato i processi e l'ho avviato esplicitamente: il comando start è terminato con [OK]. Una verifica successiva dei processi ha mostrato nuovamente Tomcat attivo.

```
/etc/init.d/tomcat5.5 restart
```

```
/etc/init.d/tomcat5.5 start
```

```

(kali@kali)-[~]
$ nc 192.168.50.101 1524
root@metasploitable:/# readlink -f /var/lib/tomcat5.5/conf/server.xml
/etc/tomcat5.5/server.xml
root@metasploitable:/# grep -n -A 1 8009 /etc/tomcat5.5/server.xml
104:  <!-- Define an AJP 1.3 Connector on port 8009 -->
105:  <Connector port="8009"
106:             enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
root@metasploitable:/# sed -i '105,106d' /etc/tomcat5.5/server.xml
root@metasploitable:/# grep -n -A 4 8009 /etc/tomcat5.5/server.xml
104:  <!-- Define an AJP 1.3 Connector on port 8009 -->
105-
106-  <!-- Define a Proxied HTTP/1.1 Connector on port 8082 -->
107-  <!-- See proxy documentation for more information about using this. -->
108-
root@metasploitable:/# /etc/init.d/tomcat5.5 restart
* Stopping Tomcat servlet engine tomcat5.5
root@metasploitable:/#
root@metasploitable:/# ps -ef | grep -i tomcat
root    8670  8607  0 18:15 ?        00:00:00 grep -i tomcat
root@metasploitable:/# /etc/init.d/tomcat5.5 start
* Starting Tomcat servlet engine tomcat5.5
root@metasploitable:/#

```

Sul target, netstat non ha restituito alcun listener sulla 8009. Ho quindi tolto la regola firewall temporanea che avevo usato sulla stessa porta e ho ripetuto Nmap da Kali: la porta risultava closed, non filtered. Questo è coerente con il connettore disattivato.

```
netstat -lntp | grep 8009
```

```
iptables -D INPUT -p tcp --dport 8009 -j DROP
```

```

root@metasploitable:/# netstat -lntp | grep 8009
root@metasploitable:/#

```

```
(kali@kali)-[~]
$ nmap -p 25,5432,8009,1524 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 18:48 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0024s latency).

PORT      STATE      SERVICE
25/tcp    filtered  smtp
1524/tcp  open      ingreslock
5432/tcp  filtered  postgresql
8009/tcp  closed    ajp13
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)

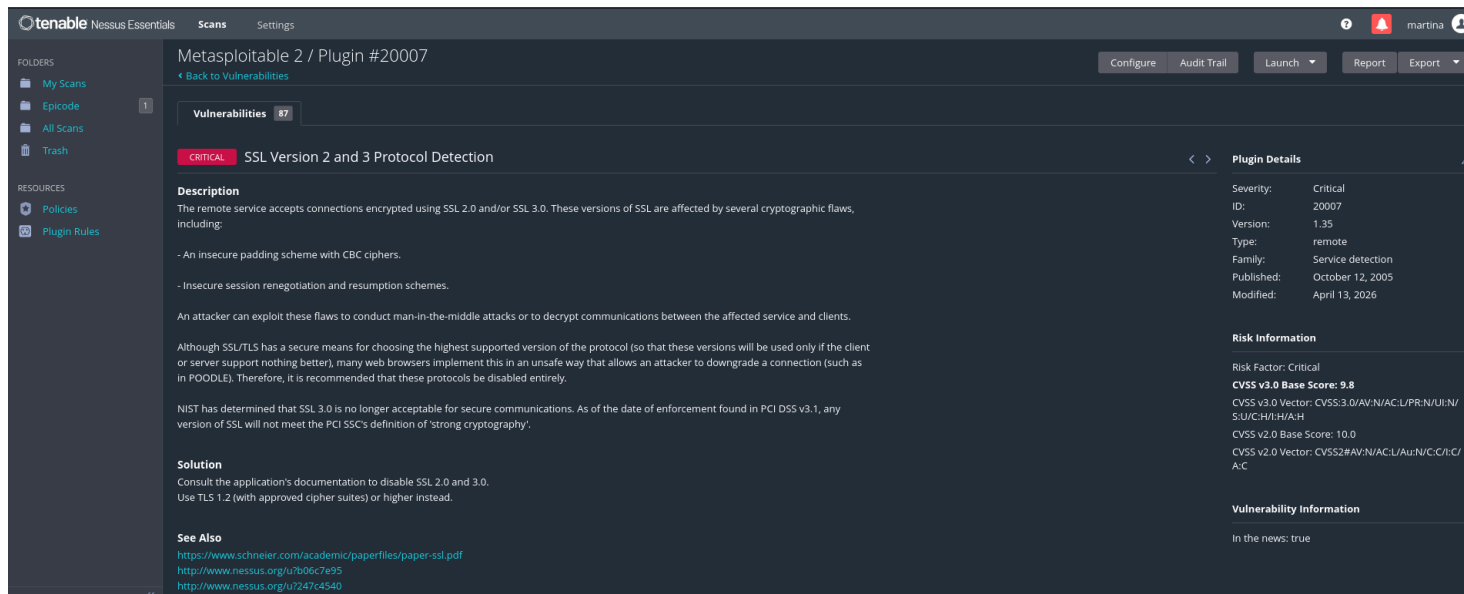
Nmap done: 1 IP address (1 host up) scanned in 5.83 seconds
```

Non ho aggiornato la versione di Tomcat: l'intervento documentato è la disattivazione del connettore AJP non necessario.

3 SSLv2 SSLv3 porte 25 e 5432

Finding Nessus	Porta/e	Intervento eseguito	Verifica disponibile
Plugin 20007 - SSL Version 2 and 3 Protocol Detection	25 e 5432/tcp	Regole INPUT DROP sulle due porte	Entrambe filtered da Kali

Nessus aveva rilevato protocolli SSL obsoleti su SMTP (porta 25) e PostgreSQL (porta 5432). Si tratta di un unico finding su due servizi. Per questa criticità ho scelto la misura consentita dalla traccia: limitare l'esposizione con il firewall. Sono due regole, ma riguardano una sola delle quattro criticità selezionate.

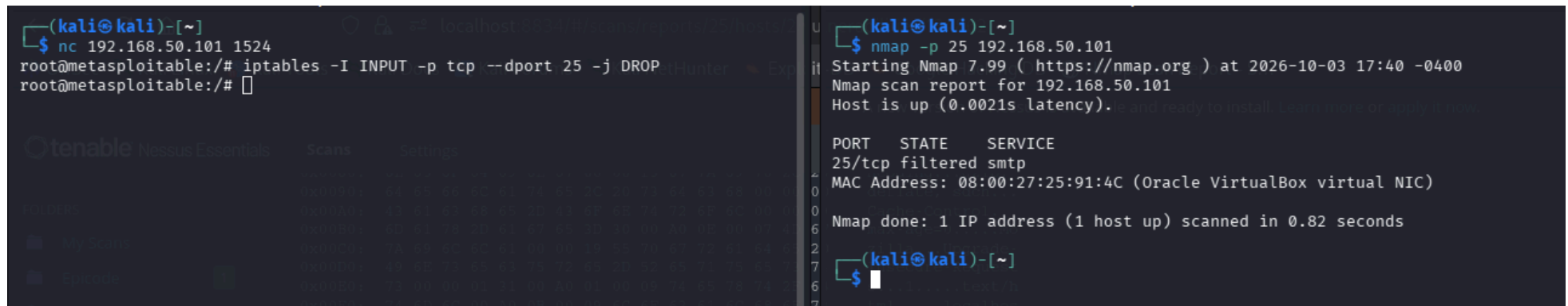


Regole applicate sul target

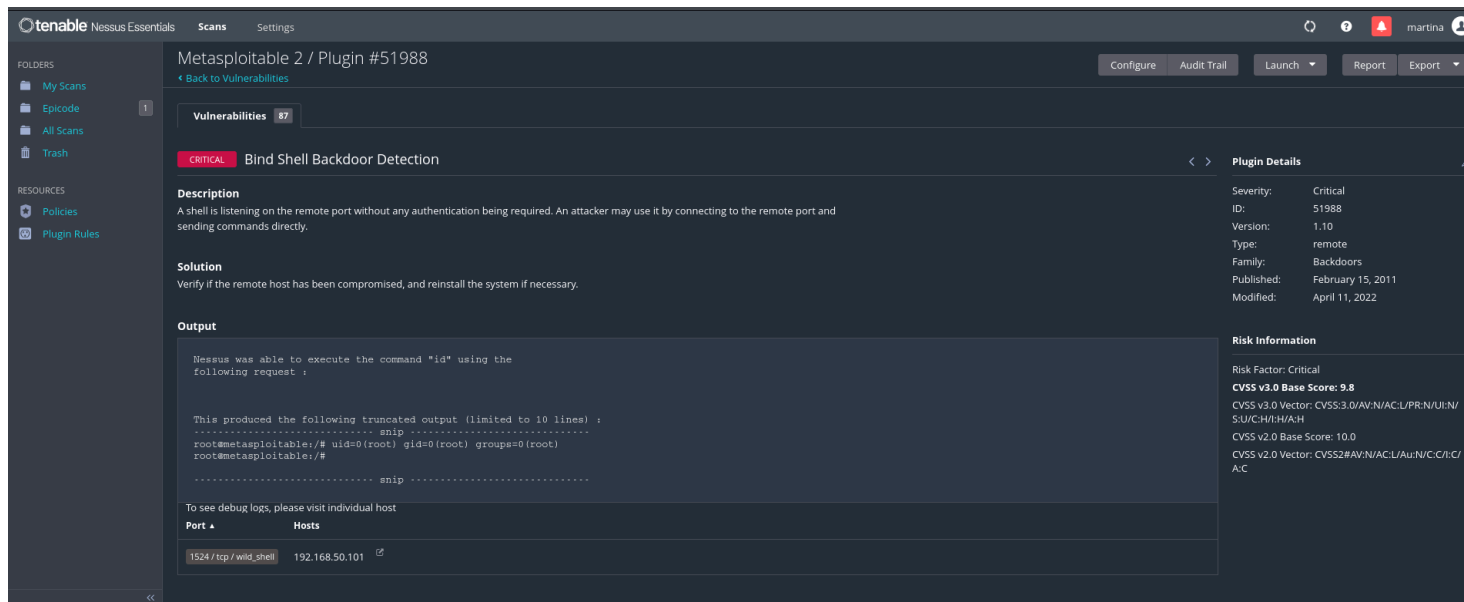
```
iptables -I INPUT -p tcp --dport 25 -j DROP
```

```
iptables -I INPUT -p tcp --dport 5432 -j DROP
```

-I INPUT inserisce la regola tra quelle in ingresso; -p tcp seleziona il protocollo TCP; --dport indica la porta di destinazione; -j DROP scarta i pacchetti che corrispondono. Dopo ciascuna regola ho controllato da Kali la porta interessata con Nmap.



```
(kali㉿kali)-[~]  
$ nc 192.168.50.101 1524  
root@metasploitable:~# iptables -I INPUT -p tcp --dport 5432 -j DROP  
root@metasploitable:~#  
  
tenable Nessus Essentials  
Scans Settings  
My Scans  
Episode  
  
(kali㉿kali)-[~]  
$ nmap -p 5432 192.168.50.101  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 17:42 -0400  
Nmap scan report for 192.168.50.101  
Host is up (0.0031s latency).  
  
PORT      STATE      SERVICE  
5432/tcp  filtered  postgresql  
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.84 seconds  
  
(kali㉿kali)-[~]  
$
```



Ricerca della voce che avvia il servizio

Ho cercato ingreslock nel file /etc/inetd.conf. Il numero 8 restituito da grep è la riga del servizio; la parte finale /bin/bash bash -i spiega perché la connessione apre una shell.

```
grep -n ingreslock /etc/inetd.conf
```

```
(kali@kali)-[~]
$ nc 192.168.50.101 1524
root@metasploitable:/# grep -n ingreslock /etc/inetd.conf
8:ingreslock stream tcp nowait root /bin/bash bash -i
root@metasploitable:/#
```

4 Bind shell modifica e verifica

Ho aggiunto # all'inizio della voce ingreslock. In /etc/inetd.conf il simbolo trasforma la riga in un commento, quindi il servizio non dovrebbe essere caricato alla successiva lettura del file. Il grep di controllo mostra 8:#ingreslock.

```
sed -i 's/^ingreslock /#ingreslock /' /etc/inetd.conf
```

```
grep -n ingreslock /etc/inetd.conf
```

```

root@metasploitable:/# sed -i 's/^ingreslock /#ingreslock /' /etc/inetd.conf
root@metasploitable:/# grep -n ingreslock /etc/inetd.conf
8:ingreslock stream tcp nowait root /bin/bash bash -i
root@metasploitable:/#

```

Il primo riavvio di openbsd-inetd non ha chiuso la porta: il controllo Nmap la mostrava ancora open. Ho quindi verificato quale processo fosse davvero in ascolto, invece di considerare riuscito l'intervento solo perché il file era cambiato.

```

Session Actions Edit View Help
--(kali@kali):~--
root@kali:~# nmap -p 25,5432,8089,1524 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2020-10-03 19:42 -0400
Nmap scan report for 192.168.50.101
Host is up (4.002s latency).
PORT      STATE SERVICE
25/tcp    open  smtp
1524/tcp   open  ingreslock
5432/tcp   filtered postgresql
8089/tcp   closed ajp13
MAC Address: 08:00:27:23:91:4C (Oracle Virtualbox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 5.85 seconds
--(kali@kali):~--

Session Actions Edit View Help
--(kali@kali):~--
webmin      10000/tcp      #
kamanda     10001/tcp      # amanda backup services (Kerberos)
kamanda     10001/udp      # amanda backup services
amandaix    10002/tcp      # amanda backup services
amandatape  10003/tcp      # Alamin SMS gateway
smqp        11201/tcp
smqp        11201/udp      # XPilot Contact Port
xpilot      15345/tcp
xpilot      15345/udp
sgl-rsmd    17003/udp      # Cluster membership services daemon
sgl-crtd    17002/udp      # SGI Group membership daemon
sgl-rsd     17003/udp      # Cluster Admin daemon
sgl-rad     17004/tcp      # isdn Logging system
isdnlsg     20011/tcp
isdnlsg     20011/udp
vbond       20012/tcp      # voice box system
vbond       20012/udp
binkp       24554/tcp      # binkp fidonet protocol
asp         27374/tcp      # Address Search Protocol
asp         27374/udp
csync2      30065/tcp      # cluster synchronization tool
dircproxy   57000/tcp      # Detachable IRC proxy
tfido       60177/tcp      # fidonet IRC over telnet
fido        60179/tcp      # fidonet IRC over TCP

# local services
root@metasploitable:/# cat /etc/services | grep ingres
ingreslock  1524/tcp
root@metasploitable:/# grep -Eri ingres /etc
grep: /etc/alternatives/vncpasswd.1.gz: No such file or directory
/etc/services:ingreslock 1524/tcp
/etc/services:ingreslock 1524/udp
/etc/tomcat5.5/server.xml: <GlobalNamingResources>
/etc/tomcat5.5/server.xml: </GlobalNamingResources>
grep: warning: /etc/tomcat5.5/tomcat5.5: recursive directory loop
/etc/tomcat5.5/server-minimal.xml: <GlobalNamingResources>
/etc/tomcat5.5/server-minimal.xml: </GlobalNamingResources>
/etc/inetd.conf:ingreslock stream tcp nowait root /bin/bash bash -i
root@metasploitable:/# sed -i 's/^ingreslock /#ingreslock /' /etc/inetd.conf
root@metasploitable:/# grep -n ingreslock /etc/inetd.conf
8:ingreslock stream tcp nowait root /bin/bash bash -i
root@metasploitable:/# ls /etc/init.d/xinetd
/etc/init.d/openbsd-inetd
/etc/init.d/xinetd
root@metasploitable:/# /etc/init.d/openbsd-inetd restart
root@metasploitable:/# ls /etc/init.d/xinetd
/etc/init.d/openbsd-inetd
/etc/init.d/xinetd
root@metasploitable:/#

```

```
netstat -lntp | grep ':1524'
```

```

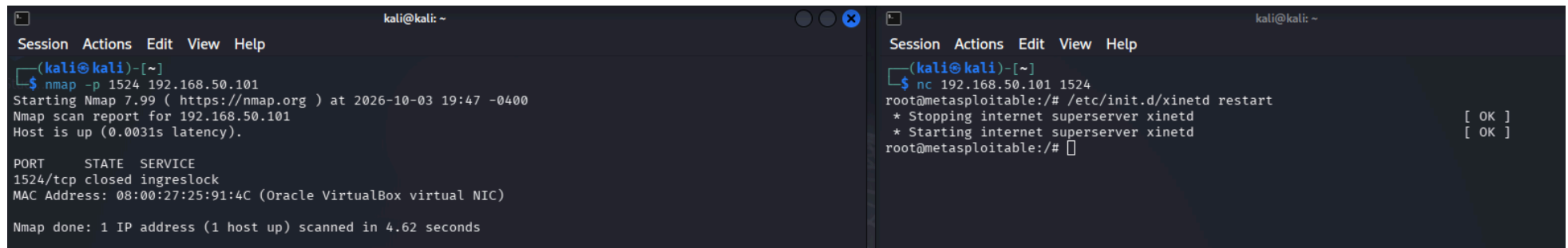
root@metasploitable:/# netstat -lntp | grep ':1524'
tcp        0      0 0.0.0.0:1524        0.0.0.0:*           LISTEN      4448/xinetd
root@metasploitable:/#

```

Ho quindi riavviato xinetd, che ha restituito [OK] sia all'arresto sia all'avvio. La nuova scansione Nmap da Kali ha mostrato 1524/tcp closed: la porta non accetta più nuove connessioni. Una shell già aperta prima del riavvio poteva ancora mostrare il prompt; non è una prova che il listener fosse rimasto attivo.

```
/etc/init.d/xinetd restart
```

```
nmap -p 1524 192.168.50.101
```



```
(kali@kali)-[~]
$ nmap -p 1524 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 19:47 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0031s latency).

PORT      STATE SERVICE
1524/tcp  closed ingreslock
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)

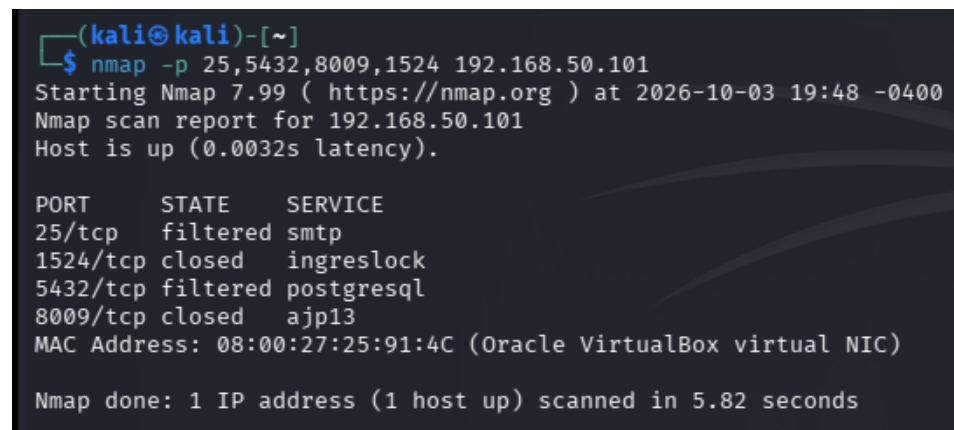
Nmap done: 1 IP address (1 host up) scanned in 4.62 seconds

(kali@kali)-[~]
$ nc 192.168.50.101 1524
root@metasploitable:/# /etc/init.d/xinetd restart
* Stopping internet superserver xinetd          [ OK ]
* Starting internet superserver xinetd          [ OK ]
root@metasploitable:/#
```

Verifica complessiva prima della nuova scansione Nessus

Dopo gli interventi ho controllato insieme le quattro porte oggetto delle modifiche ai servizi o al firewall. Il risultato distingue bene i due tipi di intervento: 8009 e 1524 sono closed perché non risultano più raggiungibili servizi in ascolto; 25 e 5432 sono filtered perché le regole firewall scartano le connessioni.

```
nmap -p 25,5432,8009,1524 192.168.50.101
```



```
(kali@kali)-[~]
$ nmap -p 25,5432,8009,1524 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 19:48 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0032s latency).

PORT      STATE SERVICE
25/tcp    filtered smtp
1524/tcp  closed  ingreslock
5432/tcp  filtered postgresql
8009/tcp  closed  ajp13
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.82 seconds
```

Sintesi dei risultati e dei limiti

Finding	Prima	Dopo: prova disponibile	Limite da dichiarare
VNC 5900	Password predefinita accettata	Vecchia negata, nuova accettata	Servizio VNC ancora raggiungibile; non mostrare la nuova password
Ghostcat 8009	Connettore AJP attivo	Connettore rimosso, Tomcat attivo, porta closed	Tomcat non aggiornato; serve controllo Nessus finale
SSL 25/5432	Servizi aperti con SSL obsoleto	Entrambe le porte filtered	Mitigazione temporanea; i protocolli non sono stati riconfigurati
Bind shell 1524	Shell root senza autenticazione	Voce commentata, xinetd riavviato, porta closed	La verifica qui riguarda nuove connessioni alla porta